| SOC L1 INCIDENT REPORT FORM | |
|---|---|
| Incident | Successful RDP brute force attack resulting in unauthorized remote access to a user workstation |
| Date & Time Detected | Mar 07, 2024 — 11:44 (UTC) |
| Analyst | Justin Benedict P. Mendoza |
| Targeted Assets | Primary affected asset:<br>● Hostname: **Matthew**<br>● IP Address: **172.16.17.148**<br>● OS: Windows 10<br>● User Account: **Matthew** |
| Detection Source | Security monitoring alert SOC176 — RDP Brute Force Detected, triggered by multiple failed authentication attempts followed by log correlation in log management and endpoint telemetry. |
| Severity | **HIGH** |

## INCIDENT SUMMARY

This report documents an incident involving a successful Remote Desktop Protocol (RDP) brute force attack against a user workstation within the monitored environment. The activity was initially detected through a security alert identifying abnormal authentication behavior, specifically a high volume of failed login attempts targeting a single host over a short period.

Further investigation revealed that external IP address 218.92.0.56 initiated repeated RDP authentication attempts against host 172.16.17.148 (Matthew) using multiple username combinations. Log analysis showed numerous Event ID 4625 (failed logon) entries, indicating systematic credential guessing consistent with brute force methodology.

A detailed timeline review confirmed that following the sequence of failed attempts, a successful authentication event (Event ID 4624) occurred using the legitimate user account Matthew with Logon Type 10 (RemoteInteractive). This event confirms that the

attacker successfully obtained valid credentials and established an interactive remote session on the system.

The progression from repeated authentication failures to a successful login demonstrates a complete attack lifecycle, beginning with credential enumeration and culminating in unauthorized system access. Based on the available telemetry, the incident is classified as a true positive brute force compromise, requiring containment and follow-up remediation to mitigate potential post-exploitation risks.

## THREAT VECTOR / INCIDENT TYPE:

The incident involved an externally sourced brute force attack targeting an exposed Remote Desktop Protocol (RDP) service, resulting in unauthorized access to a user workstation. The attack sequence demonstrates credential guessing followed by successful authentication and remote session establishment. Observed behaviors align with multiple MITRE ATT&CK techniques, as outlined below:

a. **Brute Force (T1110)** – The attacker initiated repeated authentication attempts against the target host using different username combinations, as evidenced by numerous Event ID 4625 failed logon entries within a short timeframe.
b. **Valid Accounts (T1078)** – Following multiple failed attempts, the attacker successfully authenticated using legitimate user credentials (account “Matthew”), indicating credential compromise.
c. **Remote Services – Remote Desktop Protocol (T1021.001)** – The successful authentication occurred via RDP, confirmed by Logon Type 10 (RemoteInteractive), demonstrating the use of remote services for initial access.
d. **External Remote Services (T1133)** – The attack originated from an external IP address (218.92.0.56), indicating unauthorized remote access from outside the network boundary.
e. **Account Discovery / Credential Enumeration (T1087)** – Attempts involving multiple usernames (e.g., admin, guest) suggest enumeration activity to identify valid accounts.
f. **Initial Access via Remote Service** – The sequence of failed logons followed by a successful authentication demonstrates a complete credential-based intrusion path through remote service exposure.
g. **Potential Persistence / Post-Access Risk (Contextual)** – Although not directly observed, successful interactive access introduces the risk of persistence mechanisms, lateral movement, or further reconnaissance activity.

## INITIAL ANALYSIS & EVIDENCE:

The initial analysis involved reviewing authentication logs, network activity, and endpoint telemetry to validate the alert and reconstruct the attack timeline. This process aimed to determine whether the login attempts indicated brute force behavior and to identify any evidence of successful unauthorized access.

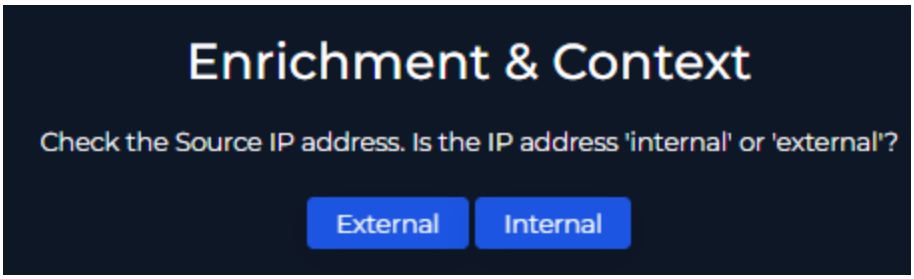
| SEVERITY | DATE | RULE NAME | EVENTID | TYPE | ACTION |
|---|---|---|---|---|---|
| Medium | Mar, 07, 2024, 11:44 AM | SOC176 - RDP Brute Force Detected | 234 | Brute Force | |

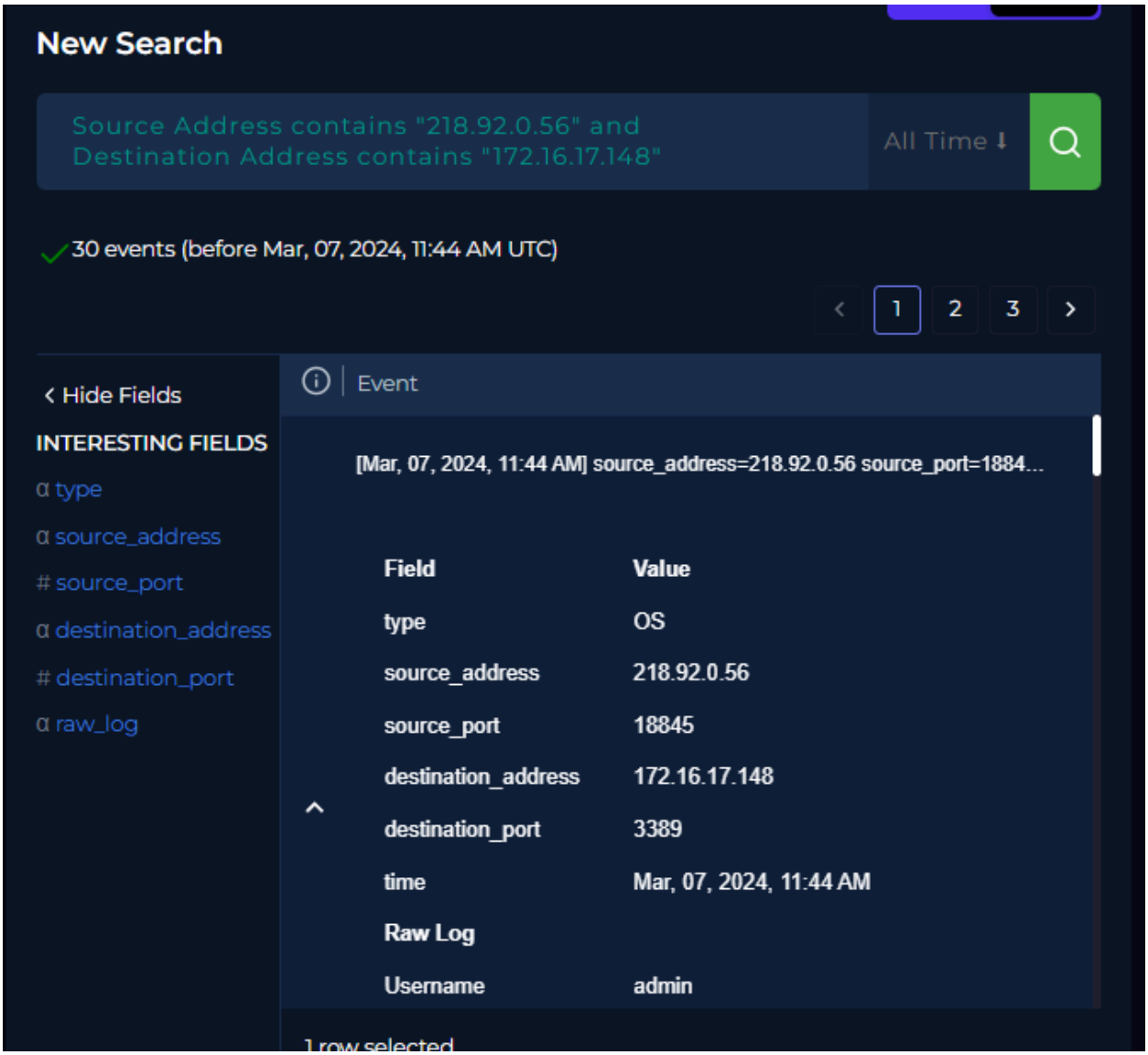
| | |
|---|---|
| **EventID :** | 234 |
| **Event Time :** | Mar, 07, 2024, 11:44 AM |
| **Rule :** | SOC176 - RDP Brute Force Detected |
| **Level :** | Security Analyst |
| **Source IP Address :** | 218.92.0.56 |
| **Destination IP Address :** | 172.16.17.148 |
| **Destination Hostname :** | Matthew |
| **Protocol :** | RDP |
| **Firewall Action :** | Allowed |
| **Alert Trigger Reason :** | Login failure from a single source with different non existing accounts |

**Show Hint**

Check Network traffic and System logs of the Host from Log Management.

Displays the triggered alert SOC176 – RDP Brute Force Detected, identifying external source IP 218.92.0.56 targeting host 172.16.17.148 (Matthew) over RDP, confirming detection of repeated failed authentication attempts consistent with brute force activity.




Shows log search results filtering traffic from source IP 218.92.0.56 to destination 172.16.17.148 over RDP (port 3389), confirming multiple connection attempts within the attack timeframe and supporting brute force activity identification.

# AbuseIPDB » *WHOIS 218.92.0.56*

Check an IP Address, Domain Name, Subnet, or ASN
e.g.
**2001:4455:177:1600:10b6:449c:b1bf:d604**, **microsoft.com**, **5.188.10.0/24**, or **AS15169**

2001:4455:177:1600:10b6:449c:b1bf:d604 CHECK

## 218.92.0.56 IP Address Information

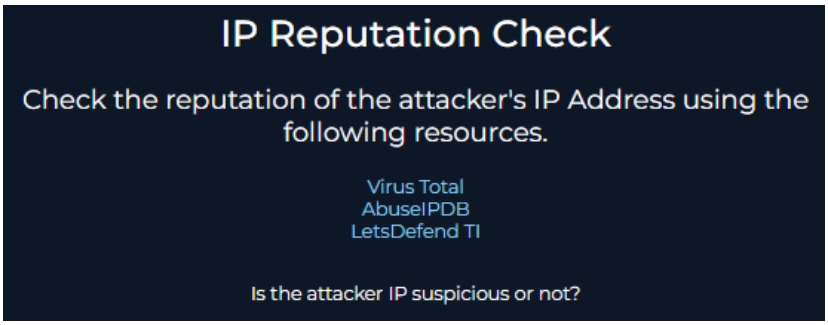
| | |
|---|---|
| **ISP** | CHINANET jiangsu province network |
| **Usage Type** | Fixed Line ISP |
| **Domain Name** | chinatelecom.cn |
| **Country** | China |
| **City** | Nanjing, Jiangsu |

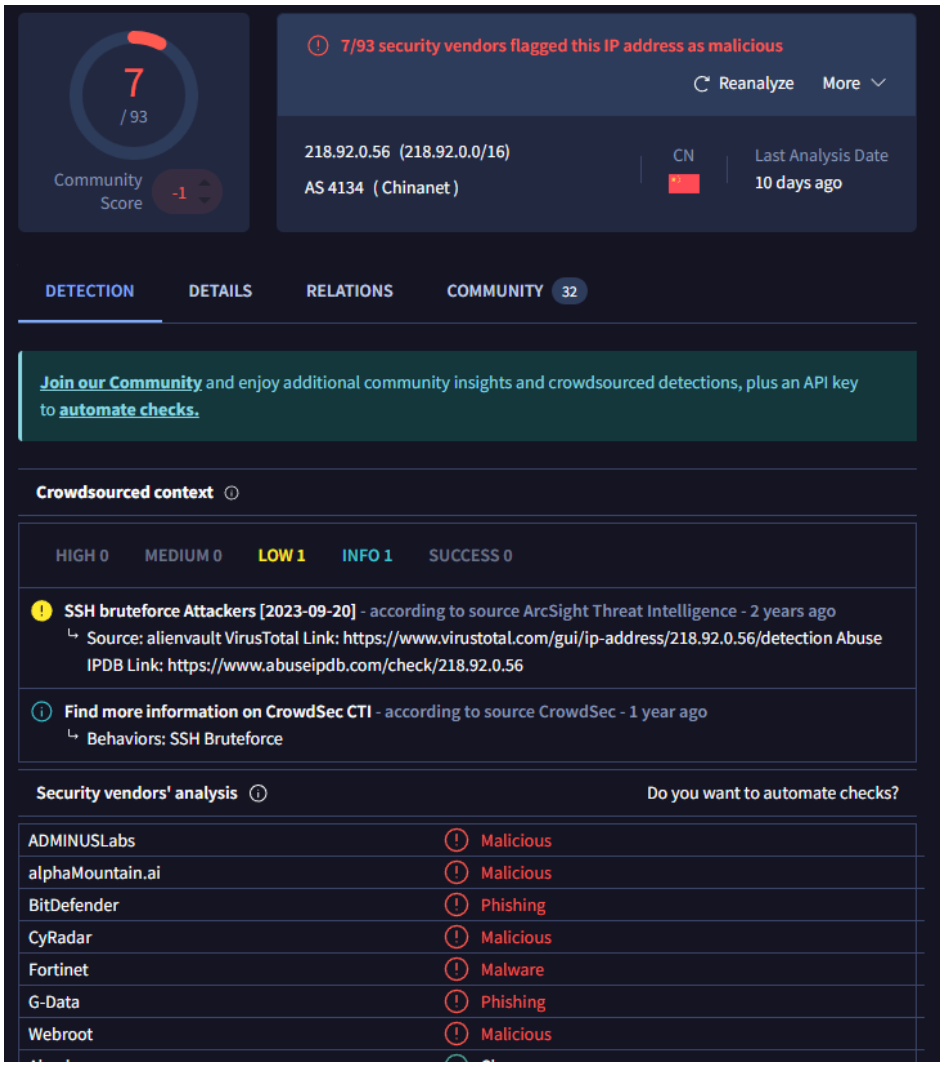
REPORT 218.92.0.56 VIEW ABUSE REPORTS

AI Overview

The IP address **218.92.0.56** is an **external (public) IP address**. AbuseIPDB +1

Displays WHOIS information for IP 218.92.0.56, identifying it as an external public address associated with the CHINANET Jiangsu network (China). This confirms the activity originated outside the organization's network perimeter.



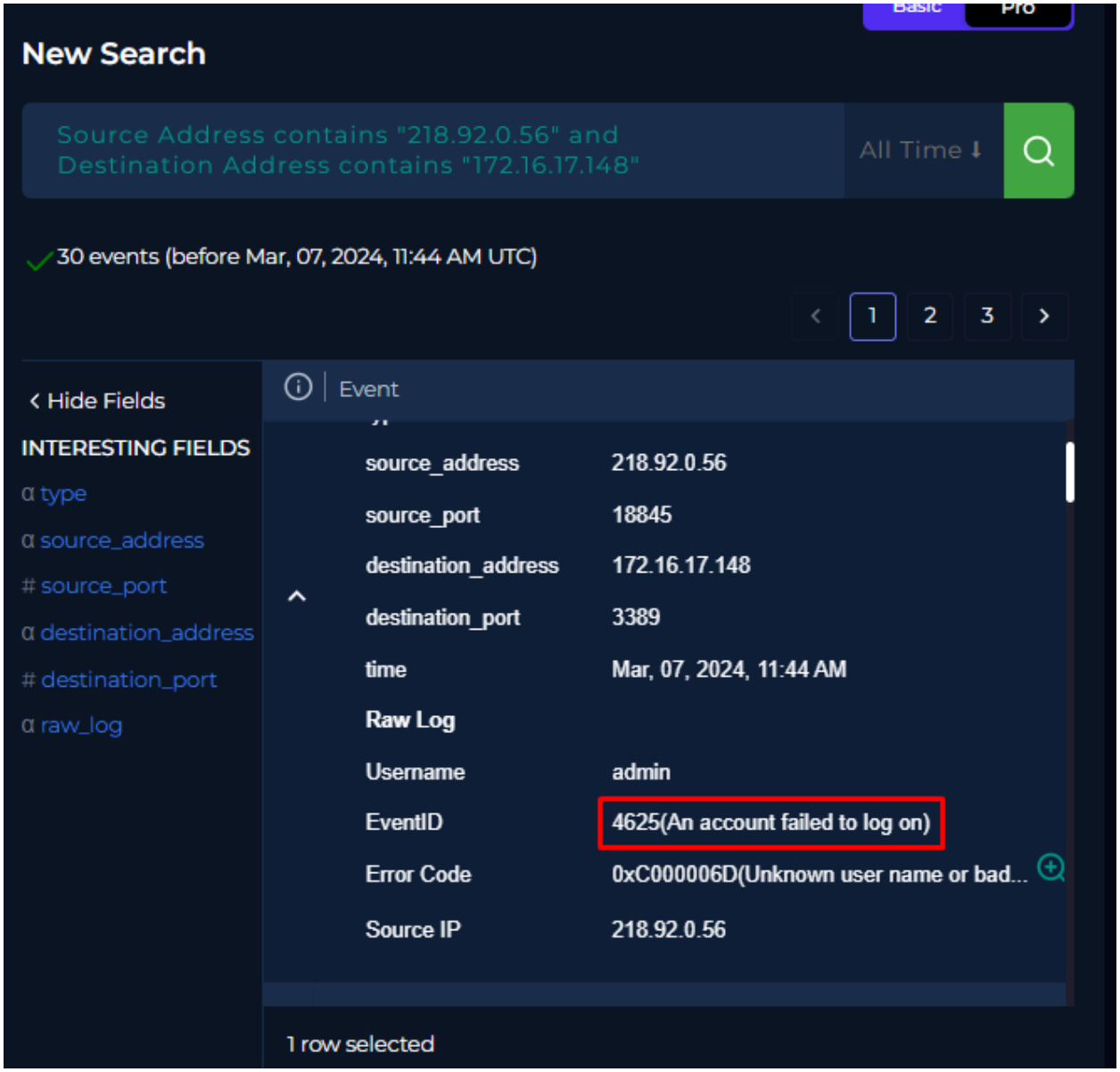




Shows VirusTotal detection results for IP 218.92.0.56, where multiple security vendors flagged the address as malicious and associated with brute force activity. This provides threat intelligence support for classifying the source IP as suspicious and linked to hostile infrastructure.

## Traffic Analysis

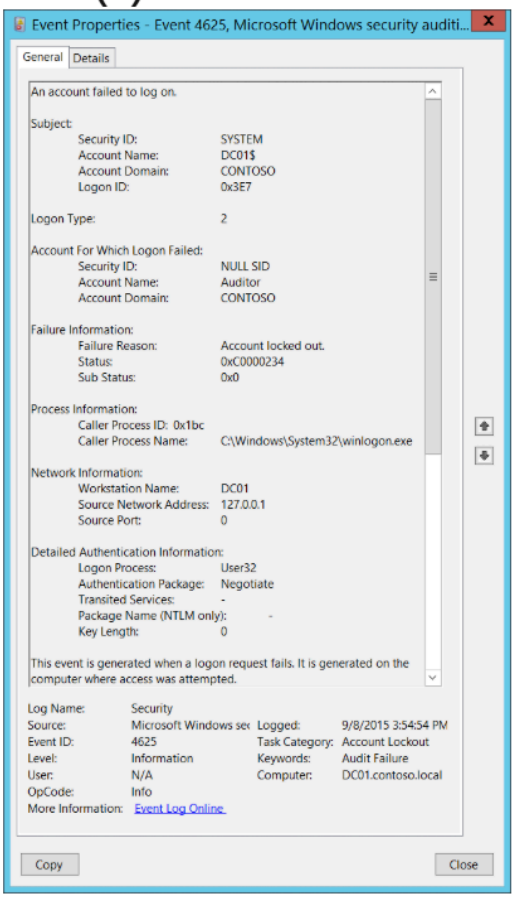
Search for the Attacker IP address in Log Management. Is there a request from the Attacker IP address to the target server's SSH or RDP port?

No Yes




Displays a Windows security log event ID 4625 for host 172.16.17.148, confirming a failed RDP logon attempt from source IP 218.92.0.56 with error code indicating invalid credentials, supporting evidence of brute force activity.

# 4625(F): An account failed to log on.



Event Properties - Event 4625, Microsoft Windows security auditi...

General | Details

An account failed to log on.

Subject:
- Security ID: SYSTEM
- Account Name: DC01$
- Account Domain: CONTOSO
- Logon ID: 0x3E7

Logon Type: 2

Account For Which Logon Failed:
- Security ID: NULL SID
- Account Name: Auditor
- Account Domain: CONTOSO

Failure Information:
- Failure Reason: Account locked out.
- Status: 0xC0000234
- Sub Status: 0x0

Process Information:
- Caller Process ID: 0x1bc
- Caller Process Name: C:\Windows\System32\winlogon.exe

Network Information:
- Workstation Name: DC01
- Source Network Address: 127.0.0.1
- Source Port: 0

Detailed Authentication Information:
- Logon Process: User32
- Authentication Package: Negotiate
- Transited Services: -
- Package Name (NTLM only): -
- Key Length: 0

This event is generated when a logon request fails. It is generated on the computer where access was attempted.

| | | | |
|---|---|---|---|
| Log Name: | Security | | |
| Source: | Microsoft Windows se | Logged: | 9/8/2015 3:54:54 PM |
| Event ID: | 4625 | Task Category: | Account Lockout |
| Level: | Information | Keywords: | Audit Failure |
| User: | N/A | Computer: | DC01.contoso.local |
| OpCode: | Info | | |
| More Information: | Event Log Online | | |

Copy | Close

***Subcategories:*** Audit Account Lockout and Audit Logon

***Event Description:***

Shows official Windows documentation for Event ID 4625, confirming it represents a failed logon attempt generated when authentication fails, supporting interpretation of repeated failed login events as brute force activity.

| Logon Type | Logon Title | Description |
|---|---|---|
| 2 | Interactive | A user logged on to this computer. |
| 3 | Network | A user or computer logged on to this computer from the network. |
| 4 | Batch | Batch logon type is used by batch servers, where processes may be executing on behalf of a user without their direct intervention. |
| 5 | Service | A service was started by the Service Control Manager. |
| 7 | Unlock | This workstation was unlocked. |
| 8 | NetworkCleartext | A user logged on to this computer from the network. The user's password was passed to the authentication package in its unhashed form. The built-in authentication packages all hash credentials before sending them across the network. The credentials do not traverse the network in plaintext (also called cleartext). |
| 9 | NewCredentials | A caller cloned its current token and specified new credentials for outbound connections. The new logon session has the same local identity, but uses different credentials for other network connections. |
| 10 | RemoteInteractive | A user logged on to this computer remotely using Terminal Services or Remote Desktop. |
| 11 | CachedInteractive | A user logged on to this computer with network credentials that were stored locally on the computer. The domain controller was not contacted to verify the credentials. |

Displays Microsoft logon type definitions highlighting Logon Type 10 (RemoteInteractive), which corresponds to Remote Desktop sessions, validating that successful authentication events in the investigation indicate RDP access.

## Determine the Scope

Does the Attacker IP address try to establish an SSH/RDP connection with multiple servers/clients as the target?

No Yes

| | |
|---|---|
| type | OS |
| source_address | 218.92.0.56 |
| source_port | 18845 |
| destination_address | 172.16.17.148 |
| destination_port | 3389 |
| time | Mar, 07, 2024, 11:44 AM |
| **Raw Log** | |
| Username | admin |
| EventID | 4625(An account failed to log on) |
| Error Code | 0xC000006D(Unknown user name or bad... |
| Source IP | 218.92.0.56 |

| | |
|---|---|
| type | OS |
| source_address | 218.92.0.56 |
| source_port | 51707 |
| destination_address | 172.16.17.148 |
| destination_port | 3389 |
| time | Mar, 07, 2024, 11:44 AM |
| **Raw Log** | |
| Username | guest |
| EventID | 4625(An account failed to log on) |
| Error Code | 0xC000006D(Unknown user name or bad... |
| Source IP | 218.92.0.56 |

| | |
|---|---|
| type | OS |
| source_address | 218.92.0.56 |
| source_port | 42044 |
| destination_address | 172.16.17.148 |
| destination_port | 3389 |
| time | Mar, 07, 2024, 11:44 AM |
| **Raw Log** | |
| Username | sysadmin |
| EventID | 4625(An account failed to log on) |
| Error Code | 0xC000006D(Unknown user name or bad... |
| Source IP | 218.92.0.56 |

| Field | Value |
|---|---|
| type | OS |
| source_address | 218.92.0.56 |
| source_port | 30844 |
| destination_address | 172.16.17.148 |
| destination_port | 3389 |
| time | Mar, 07, 2024, 11:44 AM |
| **Raw Log** | |
| Username | Matthew |
| EventID | 4625(An account failed to log on) |
| Error Code | 0xC000006A(user name is correct but... |

Displays multiple failed authentication events (Event ID 4625) originating from source IP **218.92.0.56** using different usernames, demonstrating credential enumeration behavior consistent with brute force activity targeting a single host.

# Log Management

Check the SSH/RDP audit logs to determine if the brute force attack was successful.

**For Windows:**
- Event ID 4624: An account was successfully logged on - Event ID 4625: An account failed to log on

**For Linux:**
- cat /var/log/auth.log | grep "Failed password" - cat /var/log/auth.log | grep "Accepted password"

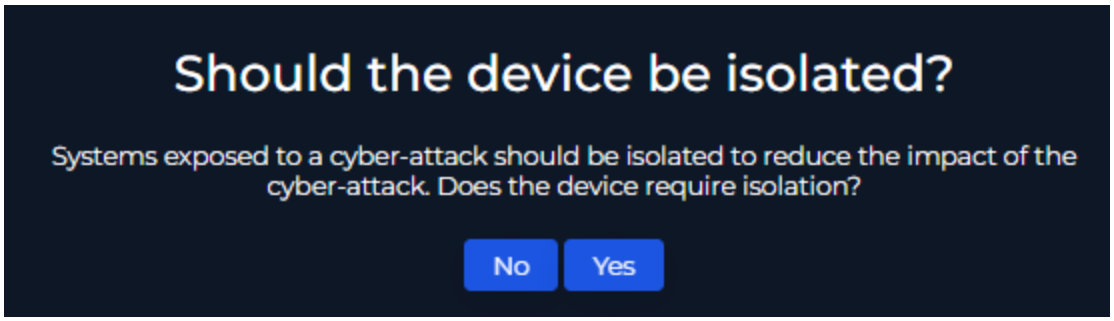
A successful login after a series of failed logins from the same source address to the same target indicates that the brute force attack was successful.

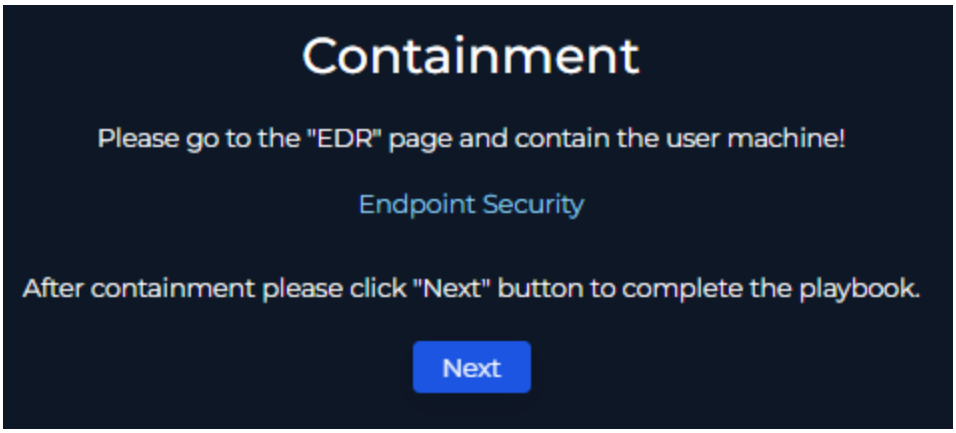
Was the brute force attack successful?

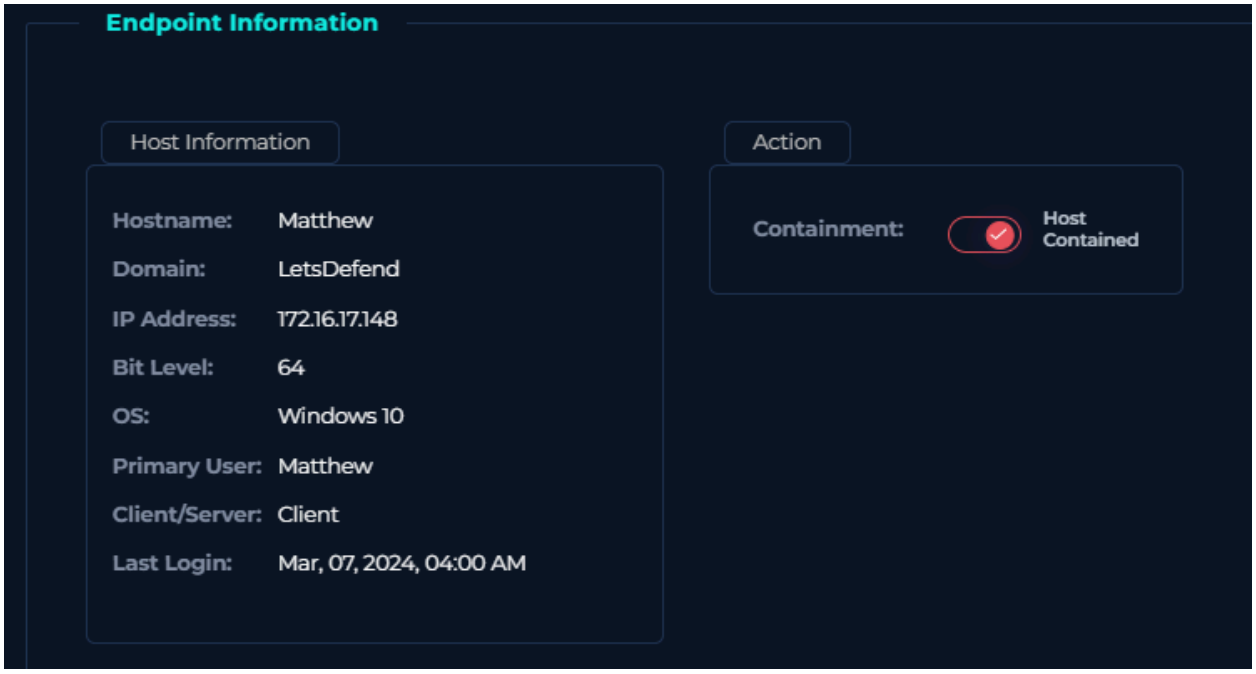
No Yes

| | |
|---|---|
| type | OS |
| source_address | 218.92.0.56 |
| source_port | 31245 |
| destination_address | 172.16.17.148 |
| destination_port | 3389 |
| time | Mar, 07, 2024, 11:44 AM |
| **Raw Log** | |
| Username | Matthew |
| EventID | 4624(An account was successfully logged on.) |
| Logon Type | 10(RemoteInteractive) |
| Source IP | 218.92.0.56 |

Displays Windows security log Event ID 4624 for user Matthew with Logon Type 10 (RemoteInteractive) from source IP 218.92.0.56, confirming successful authentication and establishing that the brute force attack resulted in unauthorized remote access.




Displays details of the affected host Matthew (172.16.17.148), including system information and confirmation that the endpoint has been contained, indicating completion of the containment phase to prevent further attacker activity.

## Lesson Learned

How did the cyber attack happen?
How well did staff and management perform in dealing with the incident?
What would the staff and management do differently the next time a similar incident occurs?
What corrective actions can prevent similar incidents in the future?
What precursors or indicators should be watched for in the future to detect similar incidents?

Next

## Add Artifacts

+

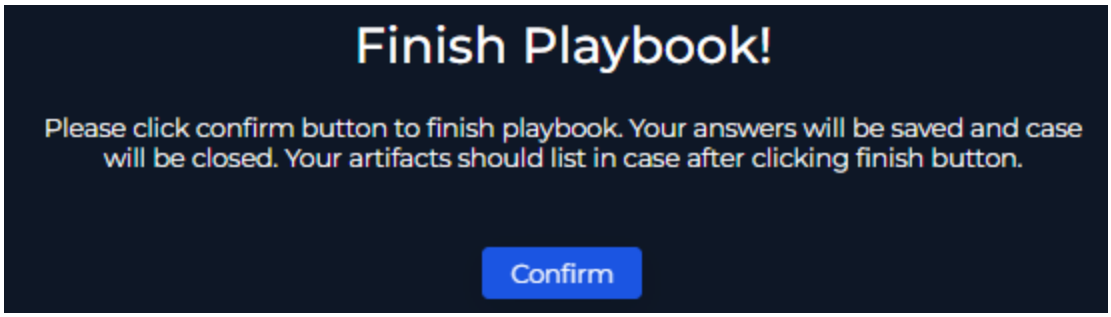
| Value | Comment | Type | Remove |
|---|---|---|---|
| 172.16.17.148 | Destination Address | IP Address | |
| 218.92.0.56 | Source IP | IP Address | |

Next

## Analyst Note

**Please enter your analysis comments.**

Investigation of alert SOC176 – RDP Brute Force Detected identified multiple failed RDP authentication attempts (Event ID 4625) from external IP 218.92.0.56 targeting host 172.16.17.148 (Matthew). Timeline analysis confirmed a subsequent successful logon (Event ID 4624, Logon Type 10), indicating that the attacker gained unauthorized remote access. The activity is assessed as a true positive brute force compromise, and the affected endpoint was contained to prevent further impact.




## IMPACT ASSESSMENT:

The impact assessment evaluates the potential and confirmed effects of the unauthorized access on the affected system and environment. This analysis focuses on determining the extent of compromise, the risks introduced by the attacker's remote session, and the potential implications for system integrity, confidentiality, and overall security posture. The evaluation was conducted in alignment with the **CERT-PH Incident Reporting and Technical Assistance Request Guidelines** to ensure standardized incident impact classification and reporting.

**Table 2: Functional Impact Guide**

| Category Rating | | Definition |
|---|---|---|
| 0 | NONE | No effect to the organization's ability to provide all services to all users |
| 1 | LOW | Minimal effect; the organization can still provide all critical services to all users but has lost efficiency *(or may happen based on the nature of cyber-attack)* |
| 2 | MEDIUM | Organization has lost the ability to provide a critical service to a subset of system users *(or may happen based on the nature of cyber-attack)* |
| 3 | HIGH | Organization is no longer able to provide some critical services to any users *(or may happen based on the nature of cyber-attack)* |

The functional impact of the incident is assessed as Low, as the compromise was limited to a single endpoint and did not affect the organization's ability to deliver critical services, although it introduced security risk.

**Table 3: Information Impact Guide**

| Category Rating | | Definition |
|---|---|---|
| 0 | NONE | No information was exfiltrated, changed, deleted, or otherwise compromised |
| 1 | INTEGRITY | Integrity Loss; Sensitive or was changed or deleted<br>*(or may happen based on the nature of cyber-attack)* |
| 2 | PRIVACY | Privacy Breach; Sensitive personally identifiable information (PII) of taxpayers, employees, beneficiaries, etc. was accessed or exfiltrated<br>*(or may happen based on the nature of cyber-attack)* |
| 3 | PROPRIETARY | Proprietary Breach; Unclassified proprietary information, such as protected critical infrastructure information (PCII), was accessed or exfiltrated |
| | | *(or may happen based on the nature of cyber-attack)* |
| 4 | CLASSIFIED | The confidentiality of classified information was compromised.<br>*(or may happen based on the nature of cyber-attack)* |

The information impact is assessed as None (0), as the investigation found no evidence of data access, modification, or exfiltration despite the confirmed unauthorized RDP session.

**Table 4: Recoverability Effort Rating Guide**

| Category Rating | | Definition |
|---|---|---|
| 0 | NOT APPLICABLE | Incident does not require recovery. |
| 1 | REGULAR | Regular; Time to recovery is predictable with existing resources |
| 2 | SUPPLEMENTED | Supplemented; Time to recovery is predictable with additional resources |
| 3 | EXTENDED | Extended; Time to recovery is unpredictable; additional resources and outside help are needed |
| 4 | NOT RECOVERABLE | Recovery from the incident is not possible (e.g., sensitive data exfiltrated and posted publicly); launch investigation |

*Ref: NIST Special Publication 800-61 - "Computer Security Incident Handling Guide"*

The recoverability effort is rated Regular (1) since the affected host was contained and can be restored using standard remediation actions such as credential resets, log review, and system validation without requiring additional resources.

## ACTIONS TAKEN:

- Validated the alert SOC176 - RDP Brute Force Detected in the SIEM and confirmed it as a true positive.
- Investigated authentication logs and identified multiple failed logon attempts (Event ID 4625) from external IP 218.92.0.56 targeting host 172.16.17.148 (Matthew).
- Correlated network and host logs to confirm activity occurred over RDP (port 3389).
- Performed threat intelligence enrichment using WHOIS, AbuseIPDB, and VirusTotal, confirming the source IP as external with malicious reputation indicators.
- Identified a successful logon event (Event ID 4624, Logon Type 10) indicating the brute force attempt resulted in unauthorized access.
- Determined scope of activity and verified the attack targeted a single endpoint.
- Executed containment by isolating the affected host via EDR to prevent further access.
- Documented indicators of compromise (IOCs), including source and destination IP addresses.
- Recorded findings and completed incident documentation in accordance with SOC procedures.

## ESCALATION DECISION:

| Color Indicator | Threat Level | Description | Report Timeframe |
|---|---|---|---|
| RED (rating 9-11) | Critical | Ransomware, C&C Server, DDOS affecting all critical sectors, Data breach with critical information exposed, wide-spread destructive compromised system, 0-day, Supply Chain attacks | 12 hours upon discovery of the incident |
| ORANGE (rating 6-8) | High | Compromised executive email, Malware infiltration, Network and system Intrusion | 18 hours upon discovery of the incident |
| YELLOW (rating 4-5) | Elevated | Detected known vulnerabilities, Idle botnets and backdoors, Unresolved signs of system intrusion(website defacements, etc.) | 24 hours upon discovery of the incident |
| BLUE (rating 2-3) | Moderate | Phishing Incidents, Compromised systems/websites with non-sensitive information | 48 hours upon discovery of the incident |
| GREEN (0-1) | Low | Unverified Anomalies | 48 hours upon discovery of the incident |

The escalation level is classified as High (Orange) due to confirmation of a successful RDP login from an external malicious IP, indicating system intrusion. Immediate containment was performed to mitigate potential lateral movement and further compromise.

## ROOT CAUSE (IF KNOWN):

**Table 5: Attack Vectors Taxonomy**

| Attack Vector | Description | Example |
|---|---|---|
| **Unknown** | Cause of the attack is unidentified. | This option is acceptable if cause (vector) is unknown upon initial report. The attack vector may be updated in a follow-up report. |
| **Attrition** | An attack that employs brute force methods to compromise, degrade, or destroy systems, networks, or services. | Denial of Service intended to impair or deny access to an application; a brute force attack against an authentication mechanism, such as passwords or digital signatures. |
| **Web** | An attack executed from a website or web-based application. | Cross-site scripting attack used to steal credentials, or a redirect to a site that exploits a browser vulnerability and installs malware. |
| **Email/Phishing** | An attack executed via an email message or attachment. | Exploit code disguised as an attached document, or a link to a malicious website in the body of an email message. |
| **External/Removable Media** | An attack executed from removable media or a peripheral device. | Malicious code spreading onto a system from an infected flash drive. |
| **Impersonation/ Spoofing** | An attack involving replacement of legitimate content/services with a malicious substitute. | Spoofing, man in the middle attacks, rogue wireless access points, and structured query language injection attacks all involve impersonation. |
| **Improper Usage** | Any incident resulting from violation of an organization's acceptable usage policies by an authorized user, excluding the above categories. | User installs file-sharing software, leading to the loss of sensitive data; or a user performs illegal activities on a system. |
| **Loss or Theft of Equipment** | The loss or theft of a computing device or media used by the organization. | A misplaced laptop or mobile device. |
| **Other** | An attack method does not fit into any other vector | |

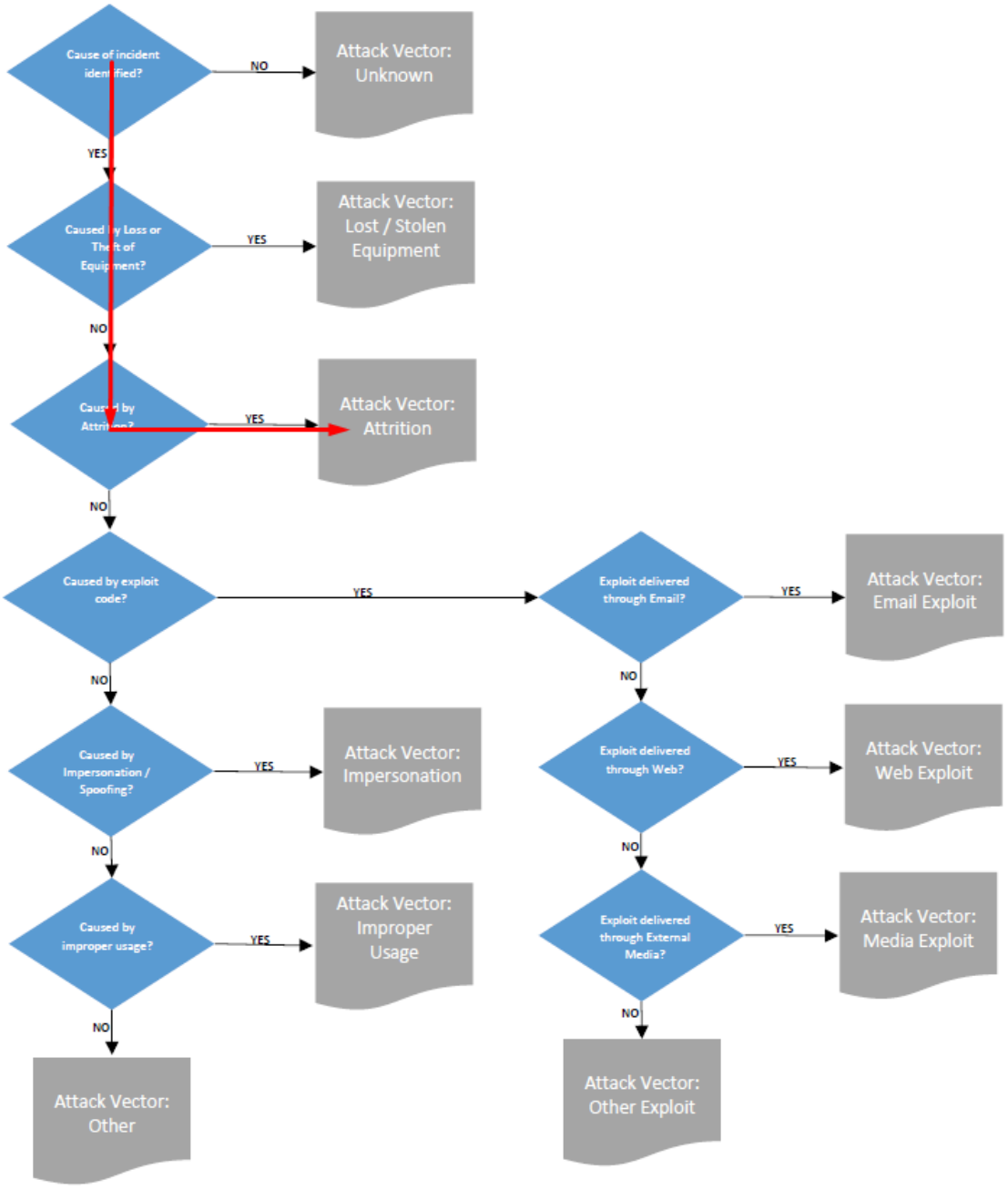
*Ref: US-CERT - "US-CERT Federal Incident Notification Guidelines"*

The incident is classified under the **Attrition attack vector** because it involved a brute force attempt against the system's RDP authentication mechanism. Log analysis

identified multiple failed logon events (Event ID 4625) from a single external IP address using different username combinations, indicating credential enumeration behavior. This activity ultimately led to a successful logon event (Event ID 4624), confirming that unauthorized access was achieved through repeated password-guessing attempts rather than exploitation of a vulnerability or delivery of malware.

**Table 6: Cause Analysis Diagram**

The diagram below will be the guide in identifying the appropriate vector:



Following the cause analysis decision flow, the incident path confirms that the cause was identified and not related to lost or stolen equipment, but instead resulted from an attrition-based attack. Evidence of repeated authentication attempts against the RDP service, including multiple failed logons followed by a successful login, aligns with brute force methodology, leading to the final classification of the attack vector as Attrition.

## INDICATORS OF COMPROMISE (IOCS) AND INDICATORS OF ATTACK (IOA)

| **Indicators of Compromise (IOC)** | **Indicators of Attack (IOA)** |
|---|---|
| Source IP address: 218.92.0.56 | Repeated authentication attempts over RDP (credential brute force behavior) |
| Target host: 172.16.17.148 (Matthew) | Multiple failed logon events (Event ID 4625) within a short timeframe |
| Successful logon event: Event ID 4624 (Logon Type 10 – RemoteInteractive) | Username enumeration attempts (admin, guest, sysadmin, Matthew) |
| External IP reputation flagged as suspicious/malicious (VirusTotal / AbuseIPDB) | External network connection targeting RDP service (port 3389) |
| Host exposure to unauthorized remote session | Brute force methodology leading to unauthorized access |

## CLOSURE NOTES

The investigation confirmed the alert as a true positive RDP brute force incident originating from an external IP address, where multiple failed logon attempts were followed by a successful remote authentication indicating unauthorized access to the host. The affected system was promptly contained to prevent further activity, and no evidence of lateral movement or data exfiltration was identified during the analysis. All relevant indicators have been documented for future monitoring, and the incident is considered resolved and closed with recommendations to strengthen security controls such as enforcing strong password policies, implementing account lockout thresholds, and restricting RDP access to trusted networks or VPN.